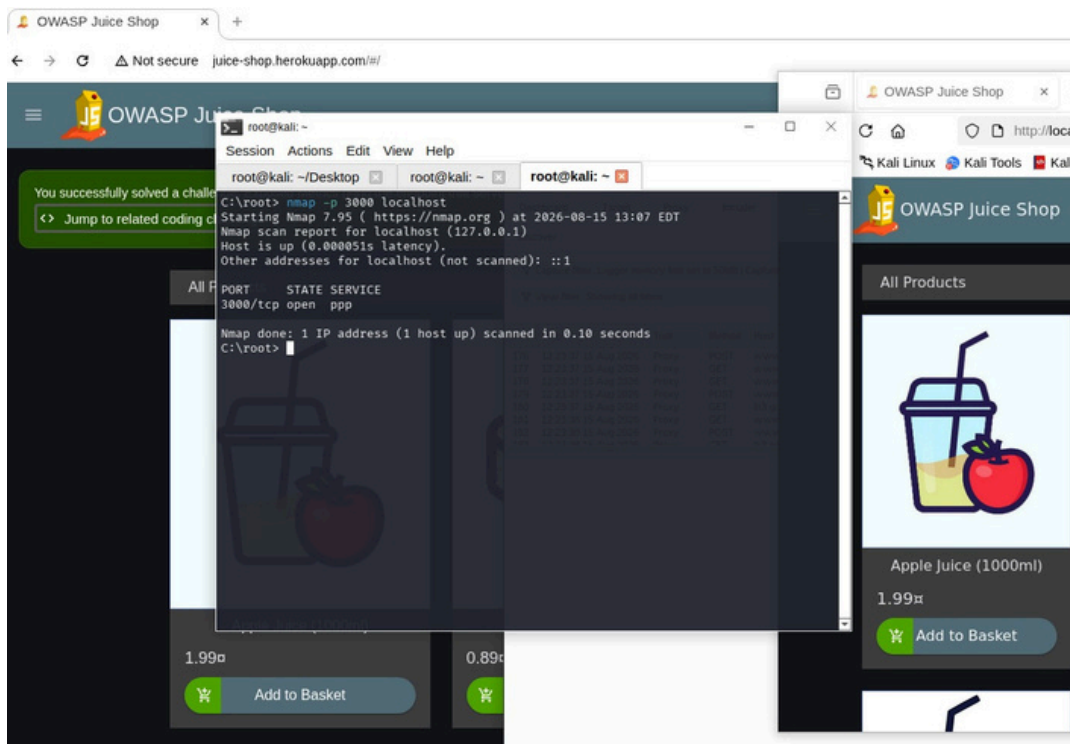
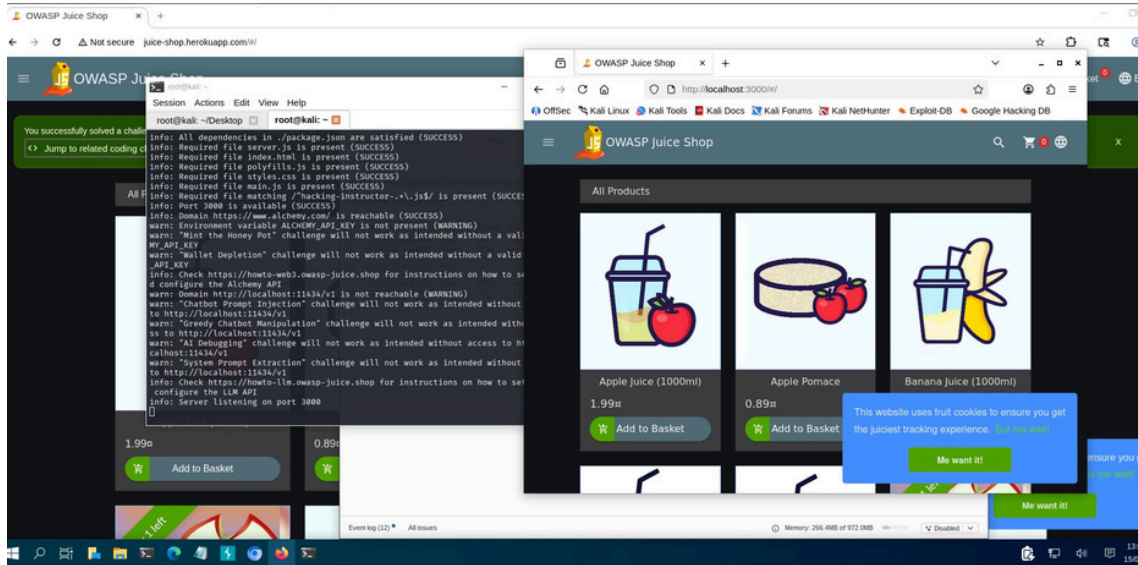


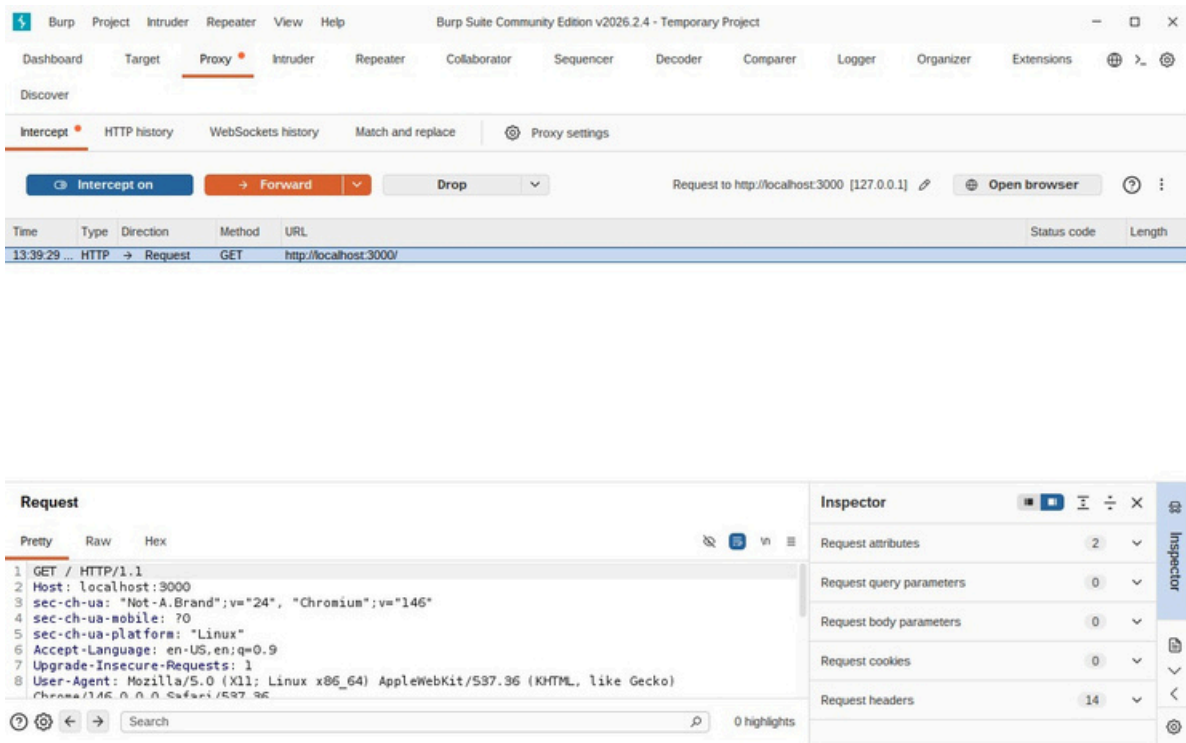
Project: Web Application Penetration Testing

- > nmap -p 3000 localhost => check open port
- > docker run --rm -p 3000:3000 bkimminich/juice-shop

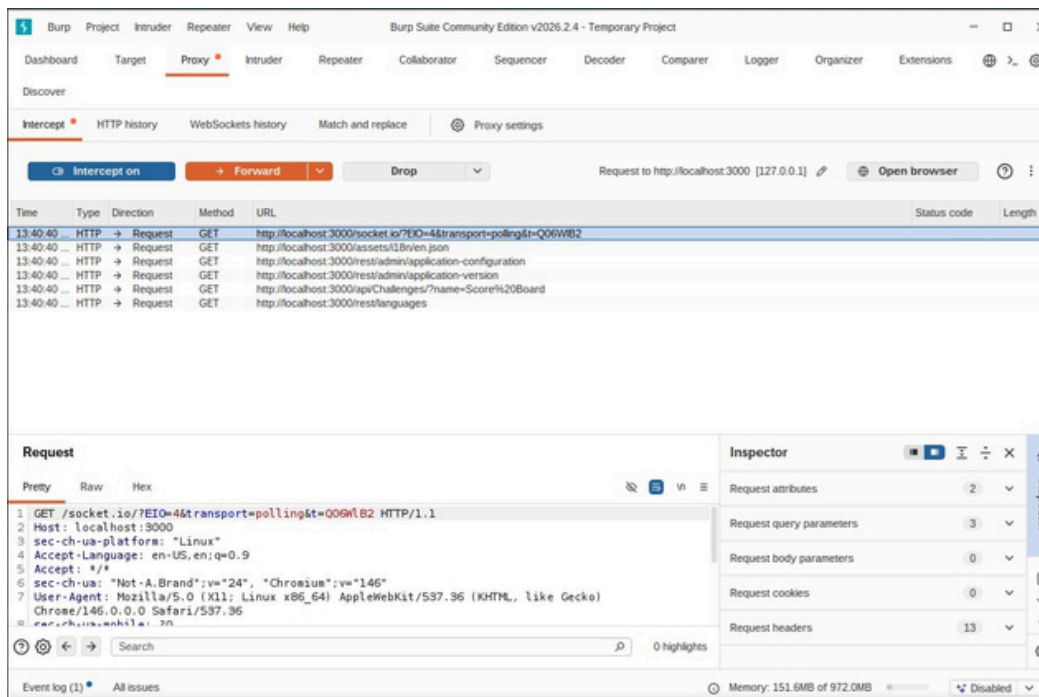


Target: OWASP Juice Shop
Target IP: localhost
Open Port: 3000/tcp
Service: Web Application

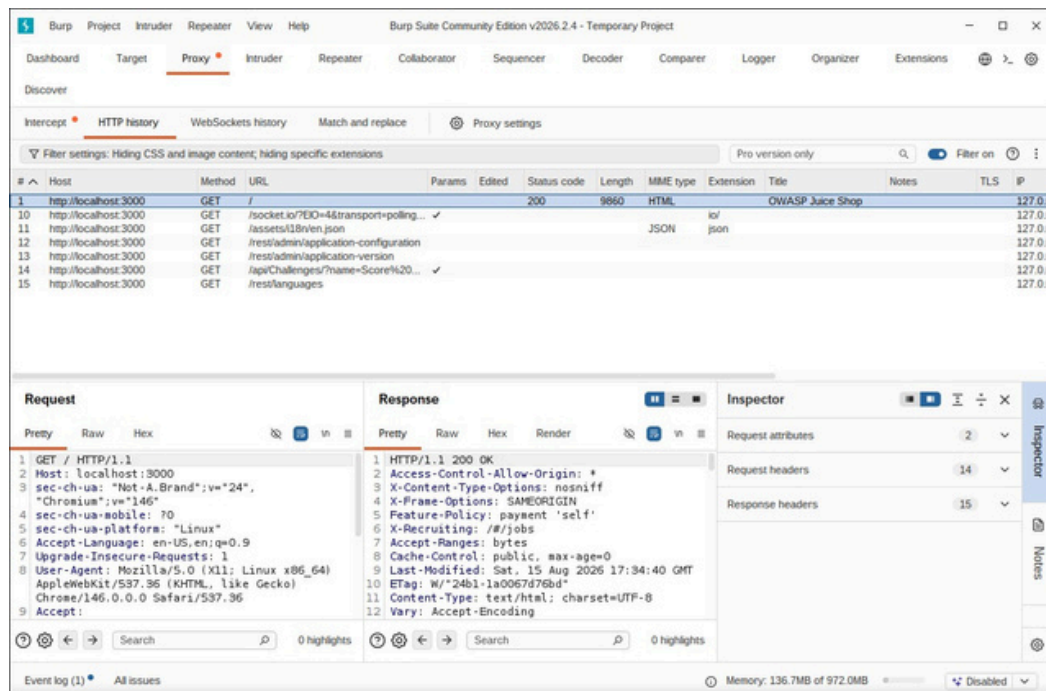
After type http://localhost:3000 on Burp



Then go to Forward



Next go to Proxy and check:



Method: GET

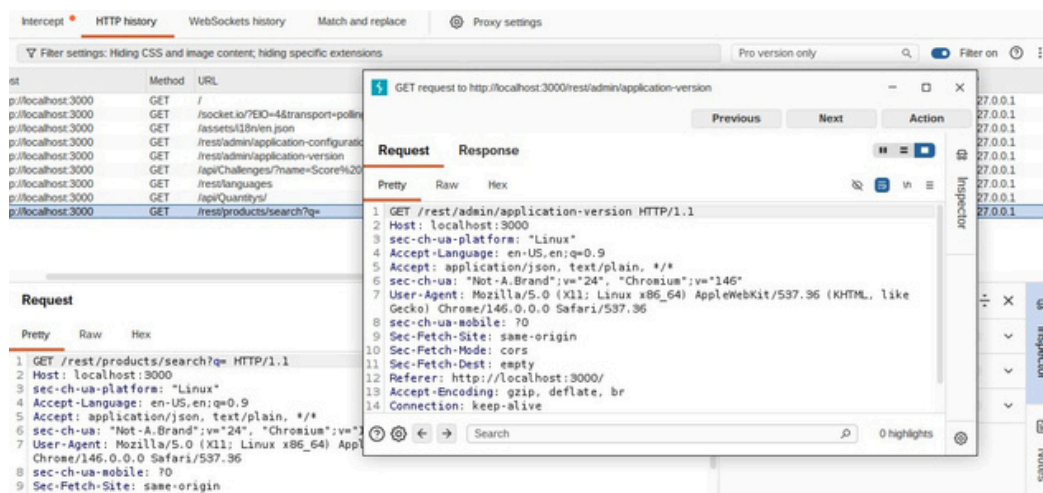
Path: /

Host: localhost:3000

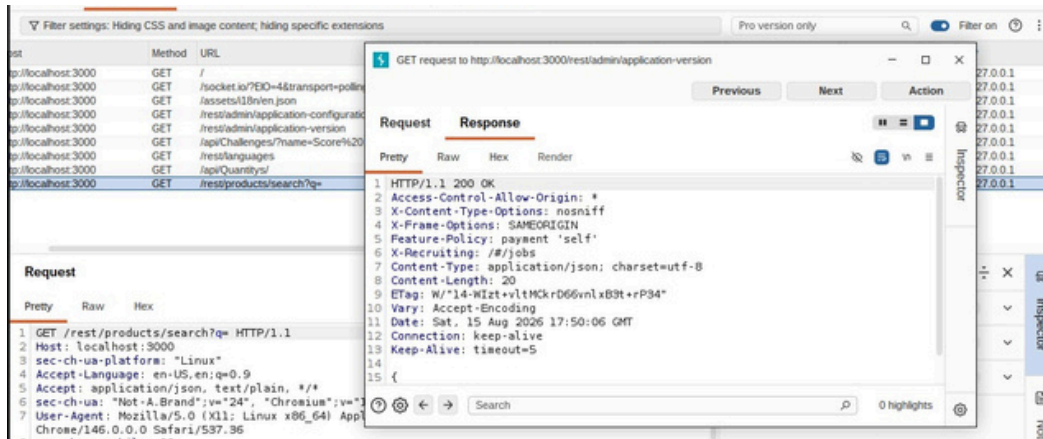
Status Code: 200

Content-Type: text/html

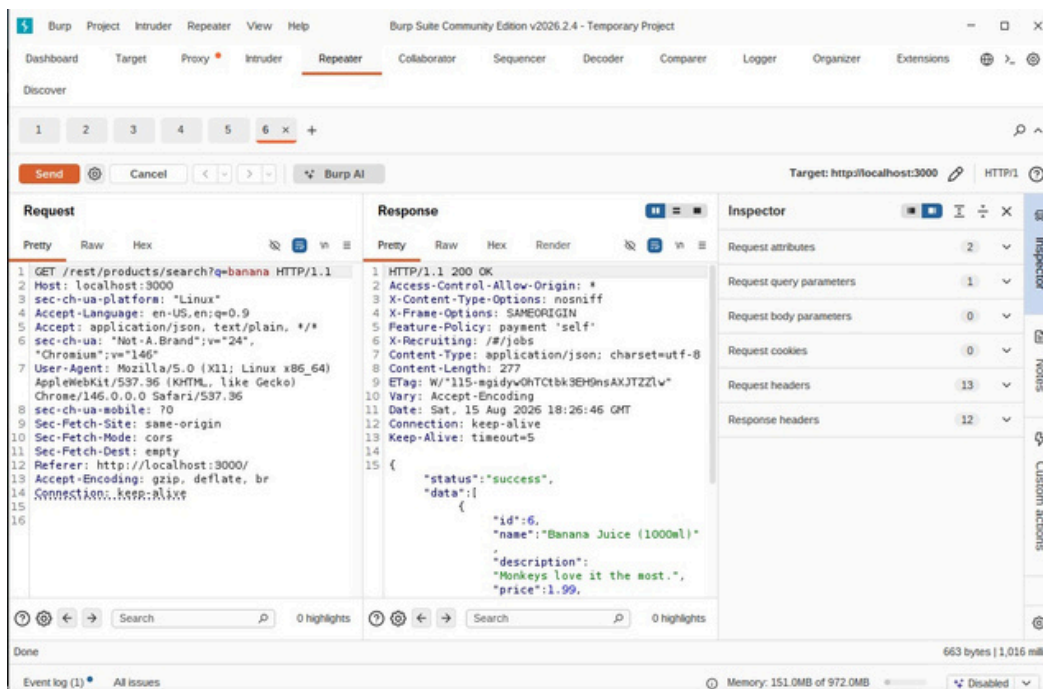
Find API Request



text/html → application/json



go to Burp juice shop web search apple
→ search?q=apple then change to banana
Then Send



parameter is banana

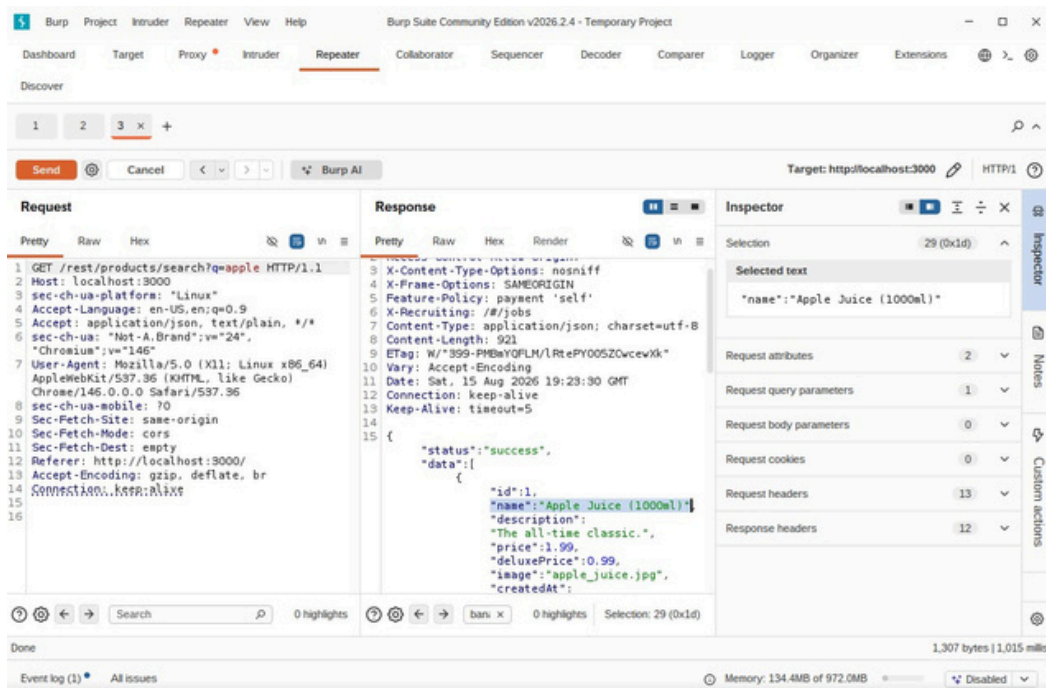
go to search taskbar type: `<script>alert(1)</script>`

Test: `<script>alert(1)</script>`

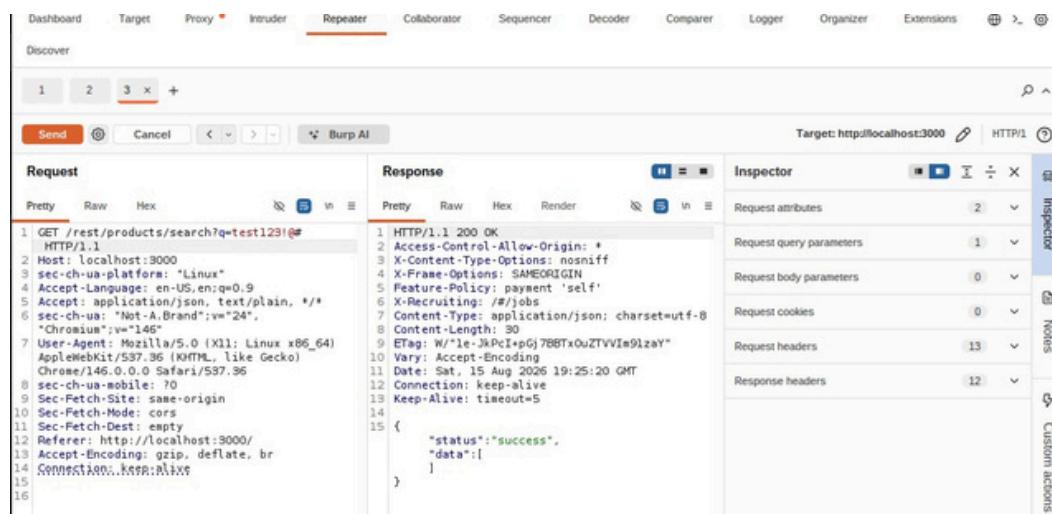
Location: Product Search

Result: No JavaScript execution

Status: Not confirmed



q=apple still code 200



q=test123!@# code 200

Search API Input Testing

Parameter: q

Normal input: apple

Special characters: test123!@#

Result: HTTP 200

Status: No vulnerability confirmed

`q=' => code: 200`

SQL Injection Testing

Endpoint: Search API

Parameter: q

Test input: '

Result: HTTP 200

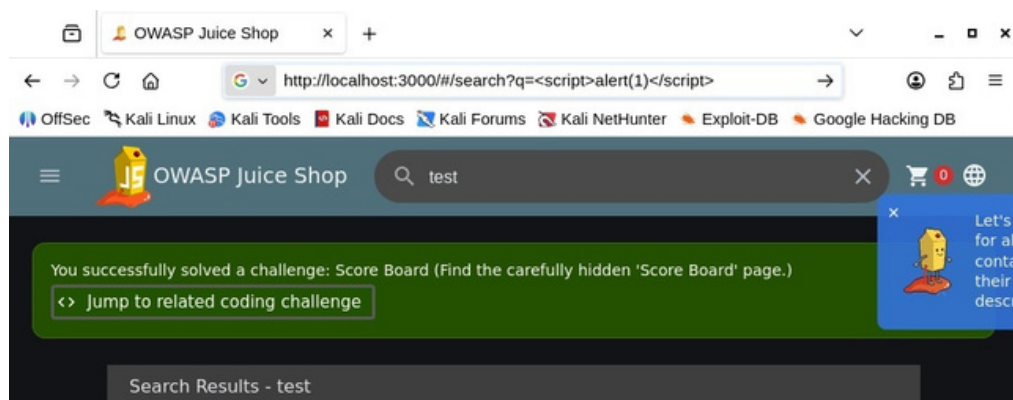
SQL error: Not observed

Conclusion: SQL Injection not confirmed

type `http://localhost:3000/#/score-board`

type test on search then check `q=test`

Then change **`q=<script>alert(1)</script>`**



No pop-up 1

Security Header: Content-Security-Policy

Result: Not observed

Target: OWASP Juice Shop

Findings Summary

Confirmed Vulnerabilities

1. DOM-Based Cross-Site Scripting (DOM XSS)

Security Observations

1. Content-Security-Policy header was not observed.
2. X-Content-Type-Options header was present.

Tests Not Confirmed

1. SQL Injection on Search parameter `q`.